

Security, costs, and ownership

How the FASTR platform protects a country's data — and what it takes to run it

»» FASTR Useful Data

Data security

The background is a solid teal color. On the right side, there are several overlapping geometric shapes. These include two large quarter-circles, one in the top right and one in the bottom right, both in a slightly darker shade of teal. Overlaid on these and the main background are several sets of concentric circles in a very light teal color, creating a subtle pattern.

What "secure" means for a platform like this

Data security for a hosted platform spans five distinct dimensions. The following slides address each in turn: the risk, and the measures in place.

Five dimensions of platform and data security

Confidentiality

Only authorized people see the data

Who can access it?

Integrity

Figures cannot be altered unnoticed

Can the numbers be trusted?

Availability

Accessible when needed

What happens if a server fails?

Sovereignty

Remains under national control

Who ultimately holds the data?

Accountability

Every action is logged

Who did what, and when?

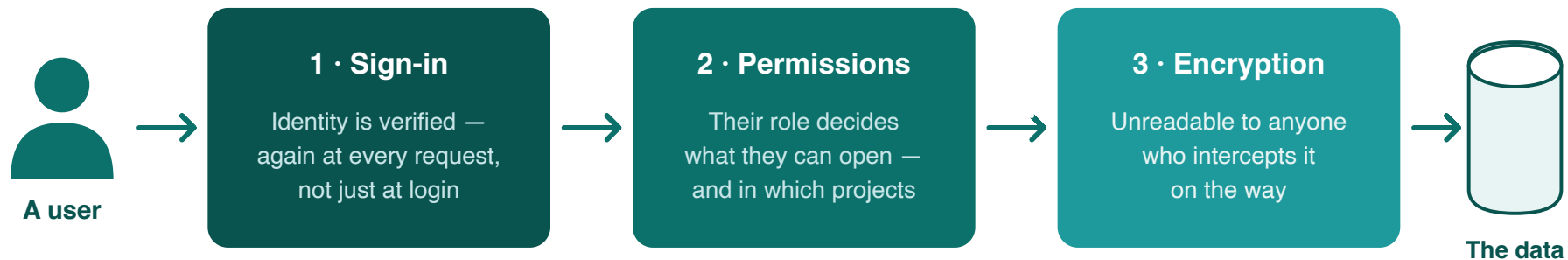
The starting point: what the platform holds

- **Monthly service totals per facility** — for example, 45 first antenatal visits at one clinic in March
- The **same figures as the DHIS2 reports** the ministry already produces
- **No patient records** — no names, no addresses, nothing individual
- **Current scope, by design:** hosting individual-level records remains possible in future, subject to the additional safeguards set out in the technical annex

Confidentiality — who can access the data

The risk: unauthorized access, from outside or inside. The measures: named accounts and roles, identity re-checked on every request, encryption in transit.

Three checks stand between a user and the data



Separately: protection against loss

The database is backed up every 30 minutes, the full installation daily — if a server fails, everything can be rebuilt

Integrity — can the figures be trusted

The risk: figures altered without record, or analyses that cannot be reproduced. The measures: one source of truth, recorded imports, versioned results.

- **DHIS2 remains the source of truth** — the platform imports from it, and re-imported months are refreshed to match it
- **Every import is recorded**: an indicator-by-indicator ledger shows the months loaded, when, and any failures
- **Results come in versioned, dated packages** — the same package gives the same numbers to everyone; new numbers require a new package
- Analysis methods and parameters are **documented and logged with each package**

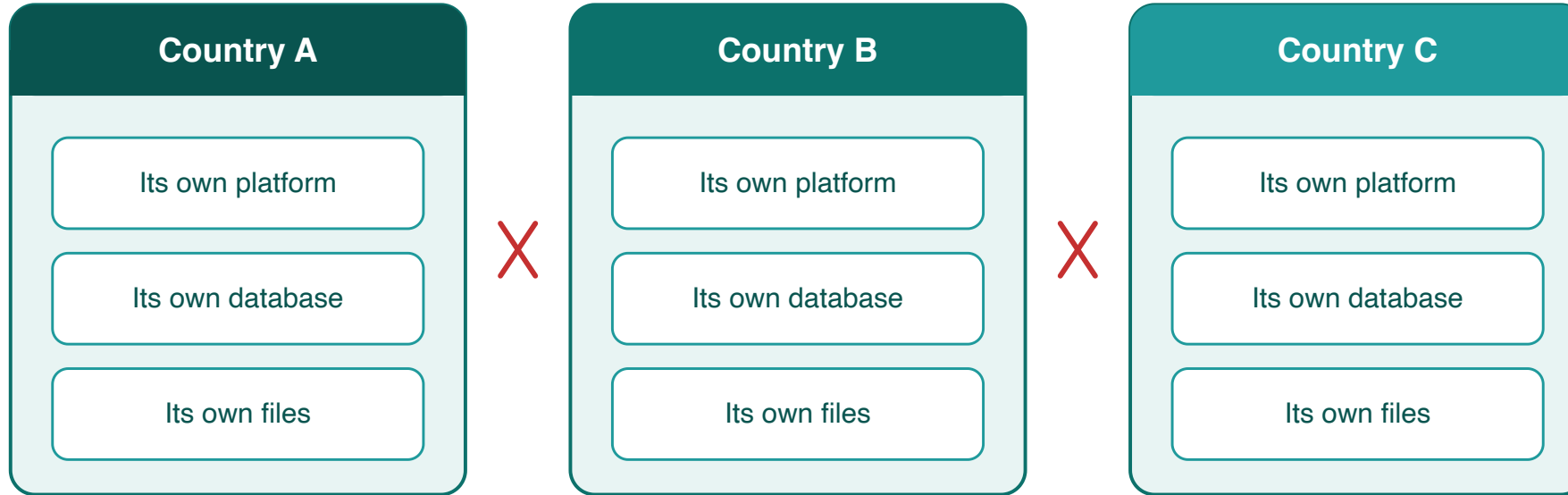
Availability — what if a server fails

The risk: hardware failure, accidental deletion, or a corrupted import. The measures: layered automatic backups and a tested recovery path.

- The **database is backed up every 30 minutes**, with a three-day rolling window
- **Full installation snapshots** are kept on a daily, weekly, and monthly cycle
- An **entire country instance can be rebuilt** from these snapshots
- Creating or restoring a backup requires **explicit permission** in addition to a valid login

Sovereignty — the data remains the country's

The risk: data flowing into a shared pool, or visible to another country. The measures: fully isolated installations, and full export at any time.



No connection between countries — by design

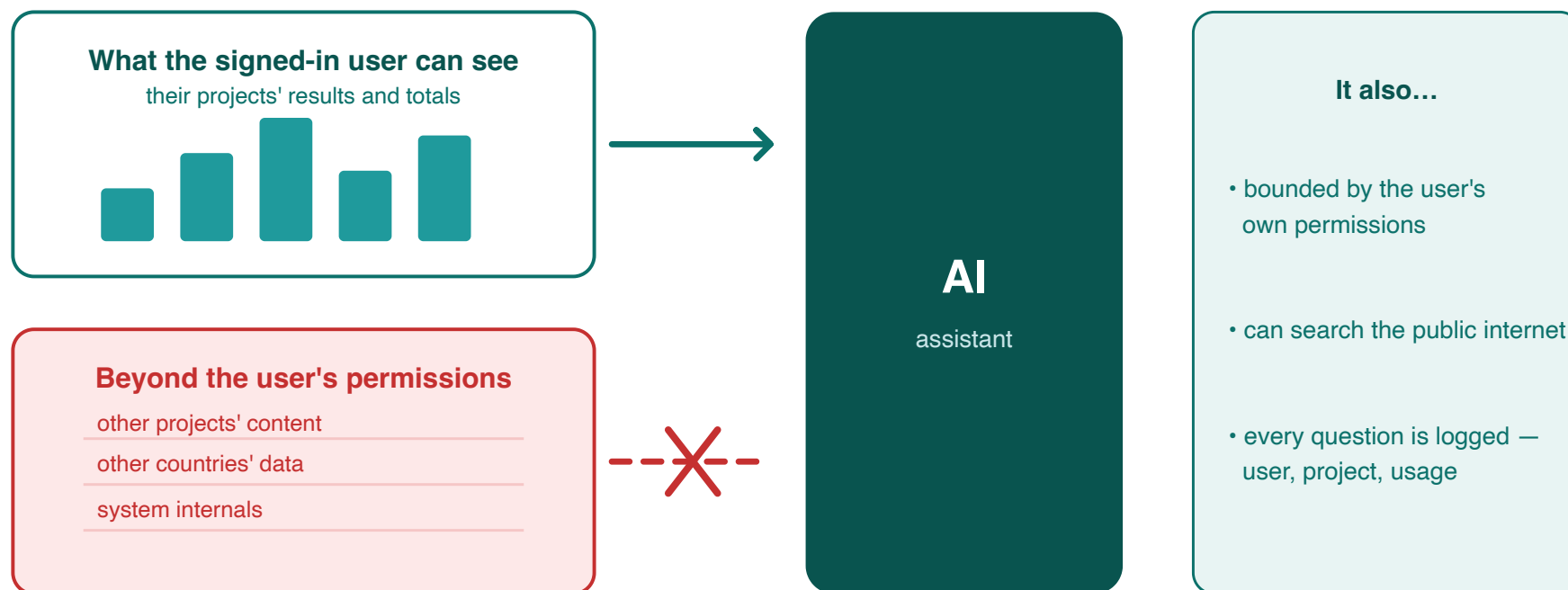
Accountability — every action attributable

The risk: changes or access nobody can trace. The measures: every request tied to a named account, and operational logs across the platform.

- Every request runs under a **named, verified account** — there are no anonymous actions
- **Imports are recorded** per indicator and month; **results packages are dated and versioned**
- **Backup and restore actions are permission-gated** and attributable
- **Every AI question is logged**: who asked, on which project, with what usage

Applied to the AI assistant

The AI sees only what the signed-in user may see, and every question is logged. It receives aggregated figures computed by the platform for that question, never the database. Under Anthropic's commercial terms those figures are **not used to train models** and are **deleted within 30 days**. Facility-level analysis, when introduced, keeps the same permission boundary.



Costs and ownership

The background features a solid teal color. On the right side, there are abstract geometric elements: a large dark teal quarter-circle in the top right, a dark teal rectangle below it, and two sets of concentric circles in the bottom right, one in dark teal and one in a lighter teal shade.

Running costs

Running costs fall into three lines: a **fixed hosting fee** for the country's server, **metered AI use** (the Anthropic API), and **shared platform maintenance**, which also covers external services such as the **Clerk login service**. The software itself is open source — there are no license or per-user fees.

Hosting	AI assistant	People
Fixed annual fee A fixed monthly amount for the country's server ≈ USD 500–800 / year	Metered by use Metered — you pay only for what people use ≈ USD 350 / month	Shared across countries Updates, monitoring, backups, user support ≈ USD 7–10k / year, shared

Planning estimates, 2026 prices — no license fees, no per-user charges

The figures — planning estimates

These are planning estimates at 2026 prices and current usage levels — **not a quote**.

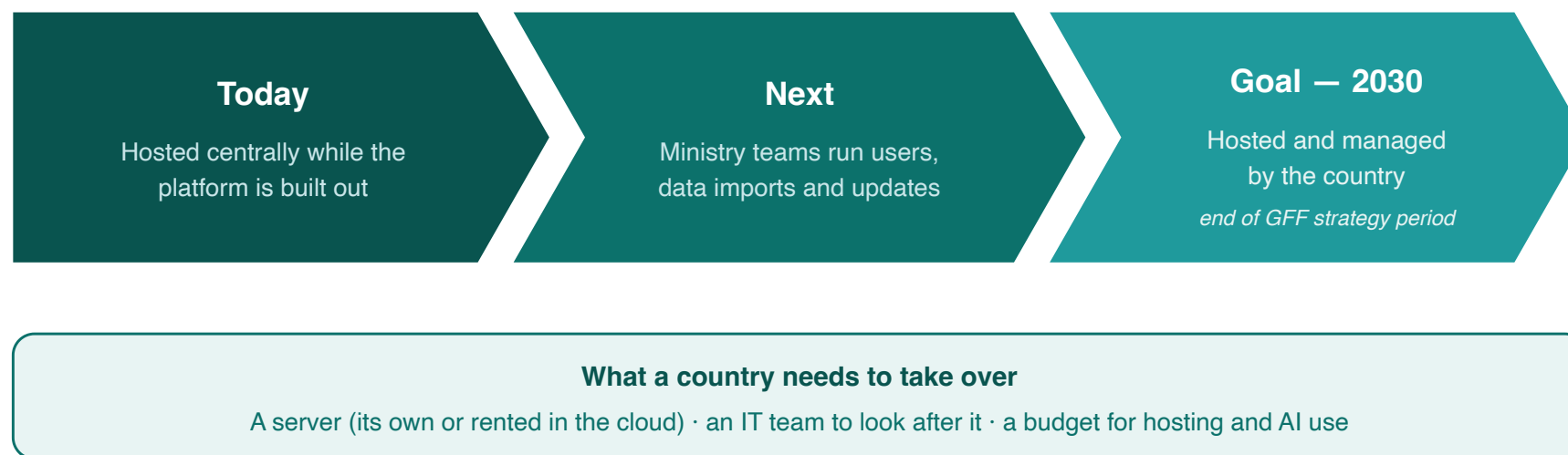
- **Hosting** a country's instance: about **USD 500–800 per year** — larger countries toward the top
- **AI use** (the Anthropic API): about **USD 350 per month** (~USD 4,000 per year) for a typical country; the largest countries several times this, growing with use
- **Shared platform maintenance** (engineering, monitoring, backups, the Clerk login service): roughly **USD 7,000–10,000 per country per year**, falling as more countries join — an economy of scale forgone under self-hosting
- **Optional support** (data refresh, quality checks, analysis): about **USD 5,000–15,000 per year**, depending on level
- **Total: about USD 12,000 per year** — up to USD 20,000–30,000 with support; no other subscriptions

Hosting — and what moving really takes

- Hosted **centrally today**, while the platform is in active development — every country receives fixes and new features the same day
- Built **portable**: the same software runs unchanged on a ministry's own servers — no rebuild needed
- **Migration is a structured project**: readiness assessment, server procurement, team training, a parallel-run period, then cutover — a **timeline of months, planned jointly**
- **Self-hosting transfers the shared functions to the ministry**: maintenance, monitoring, and applying each update — deployed centrally to all countries at once today — become the ministry team's responsibility, and one-by-one support carries additional cost
- **All of a country's data can be exported in full at any time**, now or later, regardless of hosting

The path to country ownership

For countries who do want to host themselves, there will be effort required from the Ministry of Health. A team will need to run servers, backups, and upgrades; and procurement in place for hosting and for AI services, which are bought from a commercial provider (e.g. Anthropic, OpenAI).



The essentials

- **Aggregated totals today** — no patient records; future individual-level hosting is conditional on added safeguards
- **Security on five dimensions** — isolated installations per country, role-based access, recorded imports and versioned results, layered backups, full audit trails
- **About USD 12,000 per year** to run — hosting, metered AI, shared maintenance; no license or per-user fees
- **Country hosting by 2030** — the stated goal; a structured migration that shifts updates and maintenance to the ministry, with likely additional per-country cost

Technical annex — for IT and DHIS2 teams

Architecture and isolation

- Each country instance is a **separate Docker deployment**: its own application container, its own **PostgreSQL** database, its own **Valkey** cache, its own storage volume, on a private network
- Within an instance, each project has its **own database** (`project_{uuid}`) for authoring content
- Computed results live in **versioned results packages** (parquet files, queried via DuckDB) — projects read the package attached to them, never each other's

Authentication and access control

- Identity is managed by **Clerk** (managed identity provider); session claims are **verified by middleware on every request** — auth bypass exists only for local development and is disabled in production
- **Two-tier RBAC**: instance-level permissions plus per-project roles resolved from the database on each request
- Server access: **SSH by cryptographic key only**, restricted to two named engineers — no password login

Data protection and operations

- **TLS terminates at nginx**, certificates provisioned and auto-renewed via certbot; secrets are injected as environment variables at runtime — never in images, never sent to the browser
- **R analysis modules run in ephemeral containers** (removed on completion) that mount only their own run's sandbox directory
- Backups: **pg_dump every 30 minutes** (3-day rolling window) plus **volume snapshots daily / weekly / monthly**; restores are permission-gated (`can_restore_backups`) and require a server-held key on top of a valid session

AI integration, precisely

- Claude (Anthropic) is reached through a **server-side proxy**; the API key never leaves the server
- Tool calls run **inside the user's authenticated session** — the AI holds no permissions of its own
- Data tools currently return **aggregated metric outputs** (no facility-identifier dimension as of v1.67; long dimensions summarized as counts); planned facility-level access will operate under the **same session-permission model**
- **Anthropic commercial terms**: customer content is not used to train models, is confidential, and is deleted within 30 days by default; a zero-data-retention agreement and a DPA are available; data is stored in the US
- **Server-side web search/fetch (Anthropic-hosted) is enabled** in the project chat for general questions
- Every request is logged (user, project, model, tokens); **daily per-user and weekly per-instance limits** are enforced

Data and interoperability

- Source data: **aggregated DHIS2 numerators** (facility-month service counts) — imported server-side, with per-(indicator, month) replace semantics and a per-indicator import ledger
- **Full export at any time**: a country's data and results can be exported regardless of hosting arrangement
- The codebase is **open source**: github.com/FASTR-Analytics/platform

If patient-level data were hosted: the requirements

The aggregated scope is a design decision, not a technical limit. Hosting individual-level data would be conditional on the following safeguards:

- **Legal basis first:** compliance with national data-protection and health-data law, data-sharing agreements — and possibly **in-country hosting** as a precondition
- **Encryption at rest** in addition to encryption in transit; **pseudonymization** wherever the analysis allows
- **Minimum-necessary access:** finer roles, per-field restrictions, and audit trails on every record access
- Formal **incident-response and breach-notification** procedures, independent security testing and certification-level practices
- **Ministry governance:** a designated data-access authority deciding who may see what, and why